AWS Documentation

IAM | Amazon S3 | Networking (VPC) | EC2

A practical guide to identity, storage and network fundamentals
with concepts, examples, CLI commands and best practices.

Version 1.1 | November 2026

Contents

Section	Topic
1	Introduction and shared responsibility
2	IAM: Identity and Access Management
3	Amazon S3: Simple Storage Service
4	Networking: VPC and connectivity
5	Amazon EC2: Elastic Compute Cloud
6	How the services fit together (reference architecture)
7	Security checklist
8	CLI cheat sheet and glossary

1. Introduction

Amazon Web Services (AWS) organizes its resources into **Regions** (geographic areas) that each contain multiple **Availability Zones** (isolated data centers). Three foundational topics appear in almost every AWS workload:

- **EC2** provides virtual servers (compute) that run your applications.
- **IAM** controls *who* can do *what* on *which* resources.
- **S3** stores objects (files) durably and at virtually unlimited scale.
- **VPC networking** defines how your resources are connected to each other and to the internet.

Shared responsibility model
AWS secures the cloud itself (hardware, facilities, core services). You secure what you put in the cloud: IAM policies, bucket permissions, network rules, data encryption and OS or application patching.

2. IAM: Identity and Access Management

IAM is a global service (not tied to a Region) that authenticates and authorizes requests to AWS. It is free to use.

2.1 Core concepts

Concept	Description
Root user	The account owner created at sign-up. Has unrestricted access. Enable MFA, create no access keys, and use it only for tasks that require it.
User	A long-term identity for a person or application. Can have a console password and/or access keys.
Group	A collection of users. Attach policies to the group instead of to each user.
Role	An identity with no long-term credentials that is assumed temporarily by users, services (EC2, Lambda) or other accounts. Preferred over users for workloads.
Policy	A JSON document that defines permissions (Allow or Deny) for actions on resources.

2.2 Policy types

Type	Purpose
Identity-based	Attached to users, groups or roles. Defines what that identity can do.
Resource-based	Attached to a resource (S3 bucket policy, SQS queue policy, KMS key policy). Defines who can access it.
Permissions boundary	Sets the maximum permissions an identity-based policy can grant to a user or role.
Service control policy (SCP)	AWS Organizations guardrail that limits what accounts in an OU can do.
Session policy	Passed when assuming a role to further restrict that session.

2.3 Anatomy of a policy

Each statement contains an **Effect**, one or more **Actions**, one or more **Resources**, and optionally a **Condition**. The example below grants read-only access to one S3 bucket, only from a specific IP range.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadOnlyReportsBucket",
      "Effect": "Allow",
      "Action": ["s3:GetObject", "s3:ListBucket"],
      "Resource": [
        "arn:aws:s3:::my-reports-bucket",
        "arn:aws:s3:::my-reports-bucket/*"
      ],
      "Condition": {
        "IpAddress": {"aws:SourceIp": "203.0.113.0/24"}
      }
    }
  ]
}
```

2.4 Policy evaluation logic

- By default, every request is **implicitly denied**.
- An explicit **Allow** in an applicable policy overrides the implicit deny.
- An explicit **Deny** always wins over any Allow.
- For cross-account access, both the identity policy and the resource policy must allow the action.
- SCPs and permissions boundaries can only restrict, never grant.

2.5 Roles and temporary credentials

A role has two parts: a **trust policy** (who may assume it) and **permission policies** (what it can do). Assuming a role returns temporary credentials from AWS STS that expire automatically. Example trust policy allowing EC2 to assume a role:

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Principal": {"Service": "ec2.amazonaws.com"},
    "Action": "sts:AssumeRole"
  }]
}
```

2.6 IAM best practices

- Enable **MFA** for the root user and all human users.
- Apply **least privilege**: start with minimal permissions and add only what is needed (use IAM Access Analyzer to refine).
- Use **roles** for applications and AWS services; avoid embedding long-term access keys in code.
- For people, use **IAM Identity Center** (SSO) with temporary credentials rather than many IAM users.
- Rotate or delete unused credentials; review the IAM credential report regularly.
- Use conditions (MFA required, source IP, tags, VPC endpoint) to narrow access.
- Monitor activity with **CloudTrail** and alert on sensitive events.

Common mistake
Using `"Action": "*"` with `"Resource": "*"` gives full administrator rights. Reserve it for break-glass roles and protect them with MFA and alarms.

2.7 Authentication, authorization and the request context

Authentication proves who you are (password plus MFA, access keys signed with Signature Version 4, or a role session token). **Authorization** decides what the authenticated identity may do. Every AWS API call is evaluated against a **request context** made of four parts:

- **Principal:** the user, role, federated identity or service making the call.

- **Action:** the API operation, written as `service:Operation` (for example `s3:PutObject`).
- **Resource:** the object being acted on, identified by its ARN.
- **Context keys:** extra facts such as source IP, time, MFA state, tags, VPC endpoint, or whether TLS was used.

Global condition keys start with `aws:` (for example `aws:SourceIp`, `aws:PrincipalOrgID`, `aws:RequestedRegion`). Service-specific keys use the service prefix (for example `s3:prefix`, `ec2:ResourceTag/Env`).

2.8 Amazon Resource Names (ARNs)

An ARN uniquely identifies any AWS resource and is used in the Resource element of policies. Some fields are empty for global or account-less services (for example S3 buckets have no Region or account).

```
arn:partition:service:region:account-id:resource-type/resource-id

arn:aws:iam::123456789012:role/app-role
arn:aws:s3:::my-bucket/reports/*
arn:aws:ec2:us-east-1:123456789012:instance/i-0abc1234def567890
arn:aws:ec2:us-east-1:123456789012:vpc/vpc-0123456789abcdef0
```

2.9 Managed versus inline policies

Kind	Description	When to use
AWS managed	Created and updated by AWS (for example `ReadOnlyAccess`, `AmazonS3FullAccess`).	Quick start; job-function policies. Often broader than needed.
Customer managed	Created by you, reusable, versioned (up to 5 versions) and attachable to many identities.	Preferred for least-privilege, organization-specific rules.
Inline	Embedded directly in one user, group or role; deleted with that identity.	Strict one-to-one relationships only.

2.10 Cross-account access

To let identities in Account A use resources in Account B, the recommended pattern is a role in Account B that Account A can assume:

- In Account B, create a role whose **trust policy** names Account A (or a specific role in A) as the principal, and whose permission policy grants the needed actions.
- In Account A, give the user or role an identity policy allowing `sts:AssumeRole` on the Account B role ARN.
- The caller assumes the role and receives temporary credentials. Optionally require an **external ID** when granting access to a third party to prevent the confused-deputy problem.
- For services that support resource-based policies (S3, KMS, SQS), you may instead grant Account A directly in the resource policy; both sides must still allow the action.

Use `aws:PrincipalOrgID` in resource policies to allow every account in your AWS Organization without listing them one by one.

```
"Condition": {
  "StringEquals": {"aws:PrincipalOrgID": "o-exampleorgid"}
}
```

2.11 Federation and single sign-on

- **IAM Identity Center:** central workforce sign-in across many accounts, with permission sets, integration with Microsoft Entra ID, Okta or its own directory.
- **SAML 2.0 federation:** existing enterprise identity providers issue assertions that map to IAM roles.
- **OpenID Connect (OIDC):** lets external workloads (for example GitHub Actions, Kubernetes service accounts) assume roles without long-term keys.
- **Amazon Cognito:** user pools and identity pools for end users of web and mobile applications.

2.12 Attribute-based access control (ABAC)

ABAC grants permissions based on tags rather than naming each resource, so access scales as new resources are added. The policy below lets a principal act only on EC2 instances whose `Project` tag matches the principal's own `Project` tag.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": ["ec2:StartInstances", "ec2:StopInstances"],
    "Resource": "arn:aws:ec2:*:*:instance/*",
    "Condition": {
      "StringEquals": {
        "aws:ResourceTag/Project": "${aws:PrincipalTag/Project}"
      }
    }
  }]
}
```

2.13 Requiring MFA for sensitive actions

This simplified pattern denies everything except the actions needed to set up MFA, unless the session was authenticated with MFA:

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "DenyAllExceptMfaSetupWithoutMFA",
    "Effect": "Deny",
    "NotAction": [
      "iam:CreateVirtualMFADevice", "iam:EnableMFADevice",
      "iam:ListMFADevices", "iam:ResyncMFADevice", "sts:GetSessionToken"
    ],
    "Resource": "*",
    "Condition": {"BoolIfExists": {"aws:MultiFactorAuthPresent": "false"}}
  }]
}
```

2.14 Tools for auditing and refining permissions

Tool	What it does
IAM Access Analyzer	Finds resources shared outside your account or organization, validates policies, and generates least-privilege policies from CloudTrail activity.
Credential report	CSV of all users and the status of passwords, MFA and access keys.
Last accessed information	Shows when a user, role or policy last used each service, so unused permissions can be removed.
IAM Policy Simulator	Tests what a set of policies would allow or deny without making real API calls.
CloudTrail	Records management and (optionally) data events: who did what, when and from where.

3. Amazon S3: Simple Storage Service

S3 is an object store. Data is stored as **objects** (up to 5 TB each) inside **buckets**. Bucket names are globally unique, and each bucket lives in one Region. S3 is designed for 99.999999999% (11 nines) durability.

3.1 Key concepts

Concept	Description
Bucket	Top-level container. Name must be globally unique and DNS-compliant.
Object	Data plus metadata, identified by a **key** (e.g. `logs/2026/11/app.log`).
Prefix	Key path portion that acts like a folder. S3 itself has a flat namespace.
Versioning	Keeps multiple versions of an object; protects against overwrites and deletes.
Lifecycle rules	Automatically transition objects between storage classes or expire them.
Replication	Copies objects to another bucket in the same (SRR) or different (CRR) Region.

3.2 Storage classes

Class	Best for	Notes
S3 Standard	Frequently accessed data	Low latency, highest storage price
S3 Intelligent-Tiering	Unknown or changing access patterns	Moves objects between tiers automatically
S3 Standard-IA	Infrequent access, needs fast retrieval	Lower storage price, retrieval fee, 30-day minimum
S3 One Zone-IA	Re-creatable infrequent data	Single AZ, cheaper, less resilient
S3 Glacier Instant Retrieval	Archive with millisecond access	90-day minimum
S3 Glacier Flexible Retrieval	Archive, minutes to hours retrieval	90-day minimum
S3 Glacier Deep Archive	Long-term archive (compliance)	Lowest cost, retrieval within hours, 180-day minimum

Check the AWS pricing page for current rates; prices vary by Region.

3.3 Access control in S3

S3 access is evaluated using IAM policies, bucket policies, ACLs, and Block Public Access settings together. Recommended approach:

- Keep **Block Public Access** enabled at both account and bucket level.
- Disable ACLs by setting **Object Ownership** to *Bucket owner enforced*.
- Use IAM policies for your own principals and **bucket policies** for cross-account or service access.
- Use **presigned URLs** for time-limited sharing of private objects.
- Use **VPC endpoints** plus policy conditions to keep traffic off the public internet.

Example bucket policy enforcing HTTPS-only access:

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "DenyInsecureTransport",
    "Effect": "Deny",
    "Principal": "*",
    "Action": "s3:*",
    "Resource": ["arn:aws:s3:::my-bucket", "arn:aws:s3:::my-bucket/*"],
    "Condition": {"Bool": {"aws:SecureTransport": "false"}}
  }]
}
```

3.4 Encryption

- **In transit:** TLS (HTTPS) endpoints.
- **At rest:** all new objects are encrypted by default with SSE-S3 (AES-256).
- **SSE-KMS:** keys managed in AWS KMS, with audit trail and fine-grained key policies.
- **SSE-C:** you supply the key with each request.
- **Client-side:** encrypt before uploading.

3.5 Data management features

Feature	Use it to...
Versioning + MFA Delete	Recover from accidental deletion; add protection to permanent deletes.
Object Lock	Enforce write-once-read-many (WORM) retention for compliance.
Lifecycle policies	Move logs to Glacier after 90 days, delete after 7 years.
Event notifications	Trigger Lambda, SQS, SNS or EventBridge when objects are created or removed.
Static website hosting	Serve static sites (usually fronted by CloudFront).
S3 Inventory / Storage Lens	Report on objects and analyze usage across the organization.
Multipart upload	Upload large objects in parallel parts (recommended above 100 MB).

3.6 Lifecycle example

```
{
  "Rules": [{
    "ID": "archive-then-expire-logs",
    "Status": "Enabled",
    "Filter": {"Prefix": "logs/"},
    "Transitions": [
      {"Days": 30,  "StorageClass": "STANDARD_IA"},
      {"Days": 90,  "StorageClass": "GLACIER"}
    ],
    "Expiration": {"Days": 2555}
  }]
}
```

3.7 Architecture and consistency

- S3 stores each object redundantly across a minimum of three Availability Zones (except the One Zone classes).
- The namespace is **flat**. The slash in a key such as `photos/2026/cat.jpg` is just a character; the console shows prefixes as folders for convenience.
- S3 offers **strong read-after-write consistency** for all PUT, DELETE and LIST operations: after a successful write you immediately read the latest data.
- Limits: single object up to 5 TB; a single PUT up to 5 GB (use multipart upload above that); object key up to 1,024 bytes; metadata is immutable once the object is written (copy the object to change it).
- Bucket names are global, 3 to 63 characters, lowercase letters, numbers and hyphens.

3.8 Performance tuning

S3 scales automatically. Each prefix supports at least 3,500 write (PUT, COPY, POST, DELETE) and 5,500 read (GET, HEAD) requests per second, and there is no limit on the number of prefixes, so spreading load across prefixes increases total throughput.

- **Multipart upload:** split large files into parts (5 MB to 5 GB each) uploaded in parallel and retried independently. Add a lifecycle rule to abort incomplete uploads.
- **Byte-range fetches:** download parts of an object in parallel or read only the needed section.
- **Transfer Acceleration:** uses CloudFront edge locations to speed uploads from distant clients.
- **CloudFront in front of S3:** caches popular objects and lowers latency and request costs.
- **Retry with exponential backoff:** the AWS SDKs do this by default for 503 Slow Down responses.

3.9 Replication in detail

- Requires versioning on both source and destination buckets, plus an IAM role that S3 assumes to copy objects.
- **Same-Region (SRR)** suits log aggregation or separate-account copies; **Cross-Region (CRR)** suits disaster recovery and lower latency for distant users.
- Only objects written *after* the rule is enabled are replicated automatically; use **S3 Batch Replication** to copy existing objects.
- Delete markers can optionally be replicated; permanent version deletions are not, which protects against malicious deletes.
- **Replication Time Control** provides a 15-minute replication SLA for most objects, with metrics and notifications.

3.10 Access Points, CORS and other features

Feature	Description
Access Points	Named endpoints with their own policy and optional VPC restriction. Simplify managing access for many applications sharing one large bucket.
Multi-Region Access Points	A single global endpoint that routes requests to the nearest replicated bucket.
CORS	Cross-origin resource sharing configuration so that browsers on one domain can request objects from your bucket.
Requester Pays	The requester, not the bucket owner, pays for data transfer and request charges.
Object tagging	Key-value tags on objects, used for lifecycle filters, cost allocation and ABAC.
S3 Select / Athena	Query CSV, JSON or Parquet data in place using SQL, without downloading the whole object.
Event notifications	Send events to Lambda, SQS, SNS or EventBridge (for example, process an image after upload).

3.11 Logging and monitoring

- **Server access logs:** best-effort logs of requests, delivered to another bucket.
- **CloudTrail data events:** reliable object-level API auditing (GetObject, PutObject, DeleteObject); billed per event.
- **CloudWatch metrics:** daily storage metrics and optional request metrics per bucket or prefix.
- **S3 Storage Lens:** organization-wide dashboards on usage, cost efficiency and data protection.
- **S3 Inventory:** scheduled CSV, ORC or Parquet listing of objects and metadata.

3.12 Cost model

S3 charges along several dimensions. Understanding them avoids surprises:

Dimension	Notes
Storage	Per GB-month, depends on storage class. Includes object metadata overhead in some classes.
Requests	Per 1,000 requests; PUT, COPY, POST and LIST cost more than GET.
Data transfer	Data in from the internet is free. Data out to the internet is charged. Same-Region transfer to EC2 is free; cross-Region is charged.
Retrieval	Applies to IA and Glacier classes, per GB retrieved.
Management features	Inventory, Storage Lens advanced tier, Intelligent-Tiering monitoring, replication and so on.
NAT Gateway	Traffic from private subnets to S3 through a NAT gateway is billed per GB. A gateway endpoint avoids this charge.

3.13 Troubleshooting HTTP 403 Access Denied

Check	Why it matters
Identity policy	Does the principal's IAM policy allow the action on both the bucket ARN (for list) and the object ARN (`/*`)?
Bucket policy	Is there an explicit Deny (for example non-TLS, wrong VPC endpoint, wrong IP) matching the request?
Block Public Access	Public policies and ACLs are ignored when these settings are on.
Encryption (KMS)	The caller needs `kms:Decrypt` or `kms:GenerateDataKey` on the key, and the key policy must allow it.
Object ownership	With ACLs enabled, objects uploaded by another account may not be owned by the bucket owner.
Organization SCPs	A service control policy may deny the action at the account level.
Region and endpoint	Using the wrong Region can return 301 or 403; use the bucket's Region.

4. Networking: VPC and connectivity

An **Amazon VPC** (Virtual Private Cloud) is a logically isolated virtual network in a Region. You choose the IP range (CIDR block), create subnets, and control routing and traffic filtering.

4.1 VPC building blocks

Component	Description
VPC	Isolated network defined by an IPv4 CIDR (e.g. 10.0.0.0/16) and optionally IPv6.
Subnet	A slice of the VPC CIDR inside **one** Availability Zone. Public or private depending on its route table.
Route table	Rules that decide where network traffic from a subnet is sent.
Internet Gateway (IGW)	Allows two-way internet connectivity for resources with public IPs in public subnets.
NAT Gateway	Lets instances in private subnets start outbound connections to the internet without being reachable from it. Deploy one per AZ for resilience.
Elastic IP	A static public IPv4 address you can attach to a NAT gateway or instance.
Security group	Stateful firewall at the instance (ENI) level. Allow rules only.
Network ACL	Stateless firewall at the subnet level. Allow and Deny rules, evaluated in numbered order.

4.2 Typical layout

A common two-tier design spreads subnets across at least two Availability Zones:

Subnet	CIDR (example)	AZ	Route to internet
Public A	10.0.1.0/24	az-a	0.0.0.0/0 to Internet Gateway
Public B	10.0.2.0/24	az-b	0.0.0.0/0 to Internet Gateway
Private app A	10.0.11.0/24	az-a	0.0.0.0/0 to NAT Gateway A
Private app B	10.0.12.0/24	az-b	0.0.0.0/0 to NAT Gateway B
Private data A/B	10.0.21.0/24, 10.0.22.0/24	az-a, az-b	No internet route

4.3 Security groups vs network ACLs

Aspect	Security group	Network ACL
Level	Instance / network interface	Subnet
State	Stateful (return traffic automatic)	Stateless (allow both directions)
Rules	Allow only	Allow and Deny
Evaluation	All rules evaluated	In numbered order, first match wins
Default	Deny all inbound, allow all outbound	Default NACL allows all

4.4 Connecting to AWS services privately

VPC endpoints let resources reach AWS services without traversing the internet:

- **Gateway endpoints** (S3 and DynamoDB): free, added as a route-table target.
- **Interface endpoints** (AWS PrivateLink): an elastic network interface with a private IP in your subnet; billed per hour and per GB.
- Endpoint policies can restrict which buckets or actions are reachable through the endpoint.

4.5 Connecting networks together

Option	Use case
VPC peering	One-to-one private connection between two VPCs. Non-transitive; CIDRs must not overlap.
Transit Gateway	Hub-and-spoke routing between many VPCs and on-premises networks.
Site-to-Site VPN	Encrypted IPSec tunnels over the internet to your office or data center.
Direct Connect	Dedicated private fiber link to AWS for consistent bandwidth and latency.
PrivateLink	Expose a service privately to other VPCs or accounts without peering.

4.6 DNS and traffic distribution

- **Route 53:** managed DNS with health checks and routing policies (simple, weighted, latency, failover, geolocation).
- **Elastic Load Balancing:** Application LB (HTTP/HTTPS, layer 7), Network LB (TCP/UDP, layer 4), Gateway LB (appliances).
- **CloudFront:** CDN that caches content at edge locations and shields origins such as S3 or ALB.

4.7 Create a basic VPC (CLI)

```
# Create VPC and enable DNS hostnames
VPC_ID=$(aws ec2 create-vpc --cidr-block 10.0.0.0/16 \
  --query 'Vpc.VpcId' --output text)
aws ec2 modify-vpc-attribute --vpc-id $VPC_ID --enable-dns-hostnames

# Public subnet
SUBNET_ID=$(aws ec2 create-subnet --vpc-id $VPC_ID \
  --cidr-block 10.0.1.0/24 --availability-zone us-east-1a \
  --query 'Subnet.SubnetId' --output text)

# Internet gateway + route
IGW_ID=$(aws ec2 create-internet-gateway \
  --query 'InternetGateway.InternetGatewayId' --output text)
aws ec2 attach-internet-gateway --vpc-id $VPC_ID --internet-gateway-id $IGW_ID

RT_ID=$(aws ec2 create-route-table --vpc-id $VPC_ID \
  --query 'RouteTable.RouteTableId' --output text)
aws ec2 create-route --route-table-id $RT_ID \
  --destination-cidr-block 0.0.0.0/0 --gateway-id $IGW_ID
aws ec2 associate-route-table --route-table-id $RT_ID --subnet-id $SUBNET_ID
```

4.8 IP addressing and CIDR theory

A CIDR block such as `10.0.0.0/16` has a network portion (the first 16 bits) and a host portion (the remaining 16 bits). A smaller prefix number means a larger network. Use private ranges defined in RFC 1918 for VPCs: `10.0.0.0/8`, `172.16.0.0/12` and `192.168.0.0/16`.

AWS allows VPC CIDR blocks between /16 and /28. In every subnet AWS reserves **five addresses**: the network address, the VPC router, the DNS server, one reserved for future use, and the broadcast address.

Prefix	Total addresses	Usable in an AWS subnet	Typical use
/16	65,536	65,531 (VPC only)	Whole VPC
/20	4,096	4,091	Large subnet (for example container workloads)
/24	256	251	Standard subnet
/26	64	59	Small tier
/28	16	11	Smallest allowed; endpoints, management

Plan CIDRs so that VPCs that may later be peered or attached to a Transit Gateway do not overlap. Leave room for growth and keep a documented IP address plan.

4.9 Routing in depth

- Every route table has an implicit **local** route that enables communication inside the VPC; it cannot be removed.
- When several routes match a destination, AWS uses the **most specific route** (longest prefix match).
- A subnet is **public** only if its route table has a route to an Internet Gateway *and* the instance has a public or Elastic IP.
- Each subnet is associated with exactly one route table; subnets without an explicit association use the main route table.
- Gateway route tables and edge associations allow inspection appliances to sit in the path.

Destination	Target	Meaning
10.0.0.0/16	local	Traffic inside the VPC
pl-xxxxxxxx (S3 prefix list)	vpce-xxxxxxxx	S3 via gateway endpoint
10.1.0.0/16	pcx-xxxxxxxx	Peered VPC
192.168.0.0/16	vgw-xxxxxxxx or tgw-xxxxxxxx	On-premises network
0.0.0.0/0	nat-xxxxxxxx	Everything else goes out through NAT

4.10 IPv6, ENIs and DHCP

- **IPv6:** addresses are globally unique and public. Use an **egress-only internet gateway** to let private IPv6 instances initiate outbound connections without being reachable inbound. Dual-stack subnets support IPv4 and IPv6 together.

- **Elastic network interface (ENI):** a virtual network card with a primary private IP, optional secondary IPs, a MAC address and security groups. ENIs can be moved between instances in the same AZ.
- **DHCP option sets:** control the domain name, DNS servers and NTP servers handed to instances.
- **DNS in a VPC:** enable *DNS support* and *DNS hostnames* so instances resolve private names; the Amazon-provided resolver sits at the VPC base address plus two.

4.11 Defense in depth for networks

Layer	Service	Role
Edge	AWS Shield, AWS WAF, CloudFront	DDoS protection and web request filtering (SQL injection, bots, rate limits).
Perimeter	AWS Network Firewall, Gateway Load Balancer	Stateful inspection, intrusion prevention, domain filtering, third-party appliances.
Subnet	Network ACLs	Coarse allow and deny rules by CIDR and port.
Instance	Security groups	Fine-grained, stateful rules between tiers.
Visibility	VPC Flow Logs, Traffic Mirroring, Reachability Analyzer	Observe, capture and test network paths.

A typical three-tier security group design chains groups together rather than using IP ranges:

Security group	Inbound rule	Source
alb-sg	TCP 443	0.0.0.0/0
app-sg	TCP 8080	alb-sg
db-sg	TCP 5432 (PostgreSQL)	app-sg

4.12 VPC Flow Logs

Flow Logs capture metadata about IP traffic (not payloads) at the VPC, subnet or ENI level and publish it to CloudWatch Logs, S3 or Kinesis Data Firehose. Each record shows the source and destination address and port, protocol, bytes, packets, and whether the traffic was **ACCEPT**ed or **REJECT**ed. They are the first tool to use when diagnosing blocked traffic.

```
# fields: version account-id interface-id srcaddr dstaddr srcport dstport
#         protocol packets bytes start end action log-status
# example record (wrapped for print):
2 123456789012 eni-0a1b2c3d 203.0.113.12 10.0.1.25 44321 22 6 10 840
  1730800000 1730800060 REJECT OK
```

4.13 Elastic Load Balancing compared

Type	OSI layer	Protocols	Highlights
Application (ALB)	7	HTTP, HTTPS, gRPC, WebSocket	Path and host-based routing, redirects, authentication with Cognito or OIDC, WAF integration, targets include instances, IPs and Lambda.
Network (NLB)	4	TCP, UDP, TLS	Very high throughput and low latency, static IP per AZ, preserves client IP, PrivateLink support.
Gateway (GWLB)	3	IP (GENEVE)	Inserts third-party firewalls and inspection appliances transparently.

All load balancers perform **health checks** and send traffic only to healthy targets across the enabled Availability Zones. Enable cross-zone load balancing to spread traffic evenly.

4.14 Route 53 records and routing policies

Record	Purpose
A / AAAA	Map a name to an IPv4 / IPv6 address.
CNAME	Alias one name to another (not allowed at the zone apex).
Alias	AWS-specific record that points to ELB, CloudFront, S3 websites and more; allowed at the apex and free of query charges.
MX / TXT	Mail routing and verification or policy text (SPF, DKIM).
NS / SOA	Delegation and zone authority.

Routing policy	Behavior
Simple	One record, one or more values returned.
Weighted	Split traffic by percentage (for example blue/green releases).
Latency	Route to the Region with the lowest latency for the user.
Failover	Primary and secondary with health checks.
Geolocation / Geoproximity	Route by user location or by distance to resources.
Multivalue answer	Return several healthy IPs for basic client-side balancing.

4.15 Hybrid connectivity: VPN versus Direct Connect

Aspect	Site-to-Site VPN	Direct Connect
Path	Encrypted over the public internet	Dedicated private fiber via a partner location
Setup time	Minutes to hours	Weeks (physical circuit)
Bandwidth	Up to about 1.25 Gbps per tunnel	1, 10 or 100 Gbps dedicated; smaller hosted options
Latency	Variable	Consistent and low
Encryption	IPsec built in	Not encrypted by default (add VPN or MACsec)
Cost	Hourly plus data transfer	Port-hour plus lower data transfer rates
Resilience	Two tunnels per connection	Use two connections at separate locations; often backed up by VPN

4.16 Network troubleshooting guide

Symptom	Things to check
Cannot reach instance from the internet	Public or Elastic IP assigned; route to IGW; security group inbound; NACL both directions; OS firewall.
Private instance cannot reach the internet	Route to NAT gateway; NAT gateway is in a public subnet with an Elastic IP; NACL ephemeral ports (1024-65535) allowed.
Instances in peered VPCs cannot talk	Routes in both VPCs; security groups allow the peer CIDR or group; no CIDR overlap; peering accepted.
Slow or failing S3 access from private subnet	Gateway endpoint route present; endpoint policy and bucket policy allow the request; DNS resolution enabled.
Intermittent failures	Check NACL statelessness, load balancer health checks, connection tracking limits and Flow Logs for rejects.

5. Amazon EC2: Elastic Compute Cloud

EC2 provides resizable virtual servers (**instances**) in the cloud. You choose the operating system, CPU, memory, storage and network settings, and pay only for what you use. Modern instances run on the **AWS Nitro System**, which offloads virtualization, networking and storage to dedicated hardware so nearly all host resources are available to your workload.

5.1 Core components

Component	Description
Instance	A virtual server launched in one subnet (and therefore one Availability Zone).
AMI	Amazon Machine Image: a template with the OS, software and root volume snapshot used to launch instances.
Instance type	Defines vCPUs, memory, network performance and optional GPUs or local storage.
EBS volume	Persistent network-attached block storage for the root disk and data disks.
Key pair	Public/private key used for SSH (Linux) or to decrypt the Windows administrator password.
Security group	Virtual firewall attached to the instance's network interface.
Launch template	Reusable configuration (AMI, type, network, user data, tags) used for launching instances and by Auto Scaling.
Instance profile	Container that passes an IAM role to the instance.

5.2 Instance types and naming

Names follow the pattern `family + generation + attributes . size`. For example, `m6i.large` is the **m** (general purpose) family, generation **6**, with Intel processors (**i**), size **large**. Attribute letters include **a** (AMD), **g** (AWS Graviton, Arm), **d** (local NVMe storage), **n** (enhanced networking) and **e** (extra memory or storage).

Category	Families	Best for
General purpose	M, T (burstable)	Web servers, small databases, development, balanced workloads.
Compute optimized	C	Batch processing, media encoding, high-performance web, scientific modeling.
Memory optimized	R, X, z	In-memory databases and caches, big data analytics.
Storage optimized	I, D, H	High IOPS or high sequential throughput: NoSQL, data warehousing, log processing.
Accelerated computing	P, G, Inf, Trn	GPU workloads: machine learning training and inference, graphics, video.

T-family (burstable) instances earn CPU credits when idle and spend them when busy. They suit spiky, low-average workloads; sustained high CPU can exhaust credits and throttle performance (unless unlimited mode is enabled, which may add cost). **Graviton** (Arm) instances typically offer better price-performance if your software supports Arm.

5.3 Purchasing options

Option	How it works	Best for
On-Demand	Pay per second (Linux) or per hour with no commitment.	Short-term, unpredictable or new workloads.
Savings Plans / Reserved Instances	Commit to a usage level for 1 or 3 years in exchange for a substantial discount.	Steady-state, always-on workloads.
Spot Instances	Use spare capacity at deep discounts (up to about 90 percent); AWS can reclaim with a 2-minute warning.	Fault-tolerant, flexible jobs: batch, CI, big data, stateless web fleets.
Dedicated Hosts / Instances	Physical servers dedicated to you.	Compliance or bring-your-own-license requirements.
Capacity Reservations	Reserve capacity in a specific AZ, with or without a discount commitment.	Guaranteed capacity for critical events.

5.4 AMIs

- An AMI contains a root volume snapshot, launch permissions and a block device mapping. AMIs are **Region-specific**; copy them to use in another Region.
- Sources: AWS-provided (Amazon Linux, Ubuntu, Windows), AWS Marketplace, community, or your own.
- Build a **golden AMI** with your base software and security hardening to launch consistent, faster-starting instances. EC2 Image Builder automates building, testing and distributing images.
- Share AMIs with specific accounts or organizations; encrypted AMIs require sharing the KMS key too.
- Keep AMIs patched: replace instances with new ones launched from an updated image (immutable infrastructure) rather than patching in place where possible.

5.5 Storage: EBS and instance store

Aspect	Amazon EBS	Instance store
Persistence	Persists independently of the instance	Lost when the instance stops, terminates or hardware fails
Attachment	Network-attached; detach and reattach (same AZ)	Physically attached to the host
Performance	Provisioned IOPS and throughput	Very high local NVMe performance
Backup	Snapshots stored in S3	None built in
Use	Boot volumes, databases, durable data	Caches, buffers, scratch data, replicated stores

EBS volume type	Medium	Characteristics and use
gp3	SSD	General purpose default: 3,000 IOPS and 125 MiB/s baseline, scalable independently of size. Boot volumes, dev/test, most apps.

EBS volume type	Medium	Characteristics and use
gp2	SSD	Older general purpose; IOPS tied to size with burst credits. Migrate to gp3 for lower cost.
io2 / io2 Block Express	SSD	Provisioned IOPS, highest durability and performance. Critical databases.
st1	HDD	Throughput optimized. Big data, log processing, streaming.
sc1	HDD	Cold HDD, lowest cost. Infrequently accessed large data.

Snapshots are incremental, point-in-time backups stored in S3 and can be copied across Regions and shared. Volumes can be encrypted with KMS (encryption covers data at rest, in transit between the instance and volume, and snapshots). Use Amazon Data Lifecycle Manager or AWS Backup to automate snapshots. EBS Multi-Attach lets certain io1/io2 volumes attach to multiple instances in one AZ.

5.6 Instance networking

- Each instance has a **primary private IP** for its lifetime. A **public IPv4** address assigned automatically changes when the instance stops and starts; an **Elastic IP** is static and stays with your account until released.
- Public IPv4 addresses are charged per hour, so prefer private instances behind load balancers, NAT, or Session Manager.
- **Enhanced networking** (ENA) provides higher bandwidth and lower latency on supported types.
- **Placement groups** influence how instances are placed on hardware: *cluster* (low-latency, one AZ), *spread* (each instance on separate hardware, max 7 per AZ) and *partition* (groups on separate racks for large distributed systems).
- Traffic between instances in the same AZ over private IPs is free; cross-AZ traffic is charged, so keep chatty components together where resilience allows.

5.7 Instance lifecycle

State	Description	Billing
pending	Instance is starting and being placed on a host.	Not billed
running	Ready for use.	Billed for instance time
stopping / stopped	Shut down; EBS volumes remain attached and data persists. Public IP is released unless Elastic IP.	No instance charge; EBS and Elastic IP still billed
stopping (hibernate)	RAM contents saved to the encrypted root volume for fast resume.	Storage charges only
shutting-down / terminated	Instance deleted permanently; root volume deleted by default.	Not billed

Enable **termination protection** and **stop protection** on critical instances. Use *reboot* to restart the OS on the same host without changing the public IP.

5.8 Connecting and configuring instances

- **AWS Systems Manager Session Manager:** browser or CLI shell with no open inbound ports, no bastion host and no SSH keys; access is controlled by IAM and logged. The instance needs the SSM Agent and an instance profile with the `AmazonSSMManagedInstanceCore` policy.
- **EC2 Instance Connect:** pushes a temporary SSH public key through the API.
- **SSH with key pair:** restrict port 22 to known IP ranges; never open it to 0.0.0.0/0.
- **User data:** a script (up to 16 KB) run as root on first boot to install packages and configure the instance.
- **Instance metadata service (IMDS):** an endpoint at `169.254.169.254` exposing instance details and temporary role credentials. Require **IMDSv2** (session tokens) to mitigate SSRF attacks.

```
# IMDSv2: request a token, then use it
TOKEN=$(curl -s -X PUT "http://169.254.169.254/latest/api/token" \
  -H "X-aws-ec2-metadata-token-ttl-seconds: 21600")
curl -s -H "X-aws-ec2-metadata-token: $TOKEN" \
  http://169.254.169.254/latest/meta-data/instance-id
```

5.9 High availability and Auto Scaling

A single instance is a single point of failure. Run multiple instances across Availability Zones behind a load balancer and manage them with an **Auto Scaling group (ASG)**:

- Define a launch template, subnets in two or more AZs, and **minimum, desired and maximum** capacity.
- **Target tracking** policies keep a metric near a target (for example average CPU at 50 percent). **Step** and **scheduled** scaling handle other patterns; **predictive scaling** forecasts load.
- Attach the ASG to a load balancer target group and enable ELB health checks so unhealthy instances are replaced automatically.
- Use **instance refresh** for rolling updates to a new AMI, and **mixed instances policies** to combine On-Demand and Spot.
- Design instances to be **stateless**: keep session data, files and databases in ElastiCache, S3, EFS or RDS so any instance can be replaced.

5.10 Launching an instance (CLI)

The example launches an instance in a private subnet with an instance profile, IMDSv2 required, an encrypted gp3 root volume and a bootstrap script.

```
cat > userdata.sh << 'SCRIPT'
#!/bin/bash
dnf update -y
dnf install -y nginx
systemctl enable --now nginx
SCRIPT

aws ec2 run-instances \
  --image-id ami-0123456789abcdef0 \
  --instance-type t3.micro \
  --subnet-id subnet-0123456789abcdef0 \
  --security-group-ids sg-0123456789abcdef0 \
  --iam-instance-profile Name=app-instance-profile \
  --metadata-options HttpTokens=required,HttpEndpoint=enabled \
  --block-device-mappings \
    'DeviceName=/dev/xvda,Ebs={VolumeSize=20,VolumeType=gp3,Encrypted=true}' \
  --user-data file://userdata.sh \
  --tag-specifications 'ResourceType=instance,Tags=[{Key=Name,Value=web-1}]'
```

5.11 Monitoring and status checks

- CloudWatch collects CPU, network, disk I/O and status metrics at 5-minute granularity by default; **detailed monitoring** gives 1-minute data.
- Memory and disk-space usage are **not** collected by default; install the **CloudWatch agent**.
- **System status checks** detect AWS infrastructure problems; **instance status checks** detect OS or network misconfiguration. Create alarms with auto-recover or reboot actions.
- Use CloudTrail for API activity, AWS Config for configuration drift, and Systems Manager Patch Manager for OS patching.

5.12 Best practices and cost optimization

- Right-size instances using CloudWatch metrics and AWS Compute Optimizer; review regularly.
- Prefer current-generation types and Graviton where compatible; use gp3 instead of gp2.
- Cover steady usage with Savings Plans and use Spot for interruptible work.
- Stop or schedule non-production instances outside working hours; delete unattached volumes, old snapshots and unused Elastic IPs.
- Tag everything (Name, Owner, Environment, CostCenter) for cost allocation and ABAC.
- Use IAM roles, IMDSv2, encrypted volumes, minimal security groups, and Session Manager instead of public SSH.
- Automate with launch templates, Auto Scaling and infrastructure as code (CloudFormation or Terraform) rather than manual changes.

5.13 EC2 troubleshooting

Problem	Likely causes and fixes
Cannot SSH to instance	Security group blocks port 22 or wrong source IP; no public IP or route to IGW; wrong key pair or username; key file permissions not 400. Try Session Manager.
Instance fails status check	System check: stop and start to move to new hardware. Instance check: inspect console output, fix fstab, firewall or kernel issues, or attach the volume to another instance.
InsufficientInstanceCapacity	Retry later, try another AZ or instance type, or use a Capacity Reservation.
Instance terminates immediately	EBS volume limit reached, encrypted snapshot without KMS access, or missing required AMI parts.
Application cannot call AWS APIs	No instance profile or missing permissions; metadata hop limit too low for containers; no route to endpoints.
Unexpectedly high bill	Idle large instances, NAT gateway data, public IPv4 charges, unattached EBS volumes, cross-AZ transfer.

6. How the services fit together

Consider an application running on EC2 instances in a private subnet that reads and writes files in S3:

- **Network:** instances sit in private subnets. An S3 **gateway endpoint** is added to their route table so S3 traffic stays on the AWS network and avoids NAT charges.
- **Identity:** instances use an **instance profile** (IAM role) with a policy limited to the required bucket and prefix. No access keys are stored on disk.
- **Resource policy:** the bucket policy denies any request that does not come through the VPC endpoint (`aws:SourceVpce`) and denies non-TLS traffic.
- **Encryption:** objects use SSE-KMS; the role also needs `kms:Decrypt` and `kms:GenerateDataKey` on that key.
- **Visibility:** CloudTrail data events, S3 server access logs and VPC Flow Logs record activity for auditing.

Bucket policy restricting access to a VPC endpoint:

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowOnlyFromVpce",
    "Effect": "Deny",
    "Principal": "*",
    "Action": "s3:*",
    "Resource": ["arn:aws:s3:::app-data-bucket", "arn:aws:s3:::app-data-bucket/*"],
    "Condition": {"StringNotEquals": {"aws:SourceVpce": "vpce-0abc1234def567890"}}
  }]
}
```

Caution
A Deny based on `aws:SourceVpce` also blocks the console and CLI access from outside the VPC, including administrators. Add an exception for an admin role before applying it.

7. Security checklist

Area	Check	Done
IAM	MFA on root and all users; no root access keys	[ ]
IAM	Roles used for workloads; no hard-coded keys	[ ]
IAM	Policies follow least privilege; Access Analyzer reviewed	[ ]
S3	Block Public Access enabled (account and bucket)	[ ]
S3	Default encryption on; SSE-KMS for sensitive data	[ ]
S3	Versioning and lifecycle rules configured	[ ]
S3	HTTPS-only bucket policy in place	[ ]
Network	Databases and app servers in private subnets	[ ]
Network	Security groups reference other groups, not 0.0.0.0/0 (except public ports 80/443)	[ ]
Network	VPC Flow Logs and S3 gateway endpoint enabled	[ ]
EC2	IMDSv2 required; instances use instance profiles	[ ]
EC2	EBS volumes encrypted; snapshots automated	[ ]
EC2	No SSH open to the world; Session Manager preferred	[ ]
EC2	Instances run in an Auto Scaling group across 2+ AZs	[ ]
Audit	CloudTrail enabled in all Regions; logs stored in a protected bucket	[ ]

8. CLI cheat sheet

IAM

```
aws iam create-user --user-name alice
aws iam create-group --group-name developers
aws iam add-user-to-group --user-name alice --group-name developers
aws iam attach-group-policy --group-name developers \
  --policy-arn arn:aws:iam::aws:policy/ReadOnlyAccess
aws iam create-role --role-name app-role \
  --assume-role-policy-document file://trust.json
aws iam put-role-policy --role-name app-role \
  --policy-name s3-access --policy-document file://policy.json
aws iam generate-credential-report
aws sts get-caller-identity
```

S3

```
aws s3 mb s3://my-unique-bucket-name --region us-east-1
aws s3 cp report.pdf s3://my-bucket/reports/
aws s3 sync ./site s3://my-bucket/site --delete
aws s3 ls s3://my-bucket --recursive --human-readable
aws s3 presign s3://my-bucket/reports/report.pdf --expires-in 3600
aws s3api put-bucket-versioning --bucket my-bucket \
  --versioning-configuration Status=Enabled
aws s3api put-public-access-block --bucket my-bucket \
  --public-access-block-configuration \
  BlockPublicAcls=true,IgnorePublicAcls=true,BlockPublicPolicy=true,RestrictPublicBuckets=true
aws s3api put-bucket-policy --bucket my-bucket --policy file://bucket-policy.json
```

Networking

```
aws ec2 describe-vpcs
aws ec2 describe-subnets --filters Name=vpc-id,Values=vpc-0123456789abcdef0
aws ec2 create-security-group --group-name web-sg \
  --description "Web tier" --vpc-id vpc-0123456789abcdef0
aws ec2 authorize-security-group-ingress --group-id sg-0123456789abcdef0 \
  --protocol tcp --port 443 --cidr 0.0.0.0/0
aws ec2 create-vpc-endpoint --vpc-id vpc-0123456789abcdef0 \
  --service-name com.amazonaws.us-east-1.s3 \
  --route-table-ids rtb-0123456789abcdef0
aws ec2 create-flow-logs --resource-type VPC --resource-ids vpc-0123456789abcdef0 \
  --traffic-type ALL --log-destination-type cloud-watch-logs \
  --log-group-name vpc-flow-logs --deliver-logs-permission-arn <role-arn>
```

EC2

```
aws ec2 describe-instances --filters Name=instance-state-name,Values=running \
  --query 'Reservations[].Instances[].[InstanceId,InstanceType,PrivateIpAddress]' --output table
aws ec2 start-instances --instance-ids i-0abc1234def567890
aws ec2 stop-instances  --instance-ids i-0abc1234def567890
aws ec2 terminate-instances --instance-ids i-0abc1234def567890
aws ec2 create-image --instance-id i-0abc1234def567890 --name web-golden-v1
aws ec2 create-snapshot --volume-id vol-0123456789abcdef0 --description "nightly"
aws ec2 modify-instance-metadata-options --instance-id i-0abc1234def567890 \
  --http-tokens required
aws ssm start-session --target i-0abc1234def567890
aws autoscaling describe-auto-scaling-groups
```

Glossary

Term	Meaning
AMI	Amazon Machine Image: template used to launch EC2 instances.
ASG	Auto Scaling group: manages a fleet of EC2 instances.
EBS	Elastic Block Store: persistent block volumes for EC2.
IMDS	Instance Metadata Service at 169.254.169.254.
NAT	Network address translation; lets private subnets reach the internet outbound only.
ARN	Amazon Resource Name: unique identifier for an AWS resource.
AZ	Availability Zone: one or more discrete data centers within a Region.
CIDR	Classless Inter-Domain Routing notation for IP ranges (e.g. 10.0.0.0/16).
ENI	Elastic Network Interface: a virtual network card.
KMS	Key Management Service for creating and controlling encryption keys.
MFA	Multi-factor authentication.
STS	Security Token Service: issues temporary credentials.
SSE	Server-side encryption.
WORM	Write once, read many.

Official references: docs.aws.amazon.com (IAM User Guide, Amazon S3 User Guide, Amazon VPC User Guide, Amazon EC2 User Guide) and the AWS Well-Architected Framework Security Pillar. Service features and prices change, so verify details there before production use.